MODULE 17 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Data Perimeters and Workload Identity

Only trusted identities, on trusted resources, from expected networks. Then give workloads outside AWS a way in without keys.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 17 of 52

admin@sthithapragna.com

A data perimeter allows access only when **trusted identities** reach **trusted resources** from **expected networks**.

Which control enforces which perimeter?

CONTROL	ATTACHED TO	ENFORCES
SCP	Your principals	Only trusted resources, expected networks
RCP	Your resources	Only trusted identities, expected networks
VPC endpoint policy	Network path	Only trusted identities and resources

ON THE EXAM

An SCP cannot restrict outsiders, because it only governs your own principals. That is the RCP's job.

The condition keys behind the perimeter

KEY	QUESTION IT ANSWERS
`aws:PrincipalOrgID`	Is the caller one of ours?
`aws:ResourceOrgID`	Is the target resource one of ours?
`aws:SourceIp, aws:SourceVpc`	Did it come from our network?
`aws:PrincipalIsAWSService`	Is AWS calling for itself? Exempt it
`aws:ViaAWSService`	Is a service calling on my behalf? Exempt it

ON THE EXAM

Network conditions without the service exemptions break services that call other services for you.

Resource control policies

- **Set in Organizations**, like SCPs, but evaluated on access to your resources.
- **Apply to any caller**, including principals outside your organisation.
- **Supported services include** S3, STS, KMS, SQS and Secrets Manager.
- **Cover future resources** without editing each bucket or key policy.
- **Grant nothing**, and do not apply to the management account.

> ON THE EXAM
>
> Stop outsiders reaching any bucket, including ones a team creates tomorrow: an RCP.

Validating the perimeter holds

- **External access analyser** reports anything shared beyond the zone of trust.
- **Archive rules** mark expected sharing, such as with a known partner.
- **Custom policy checks** stop new external access before deployment.
- **Findings flow to Security Hub** for central triage.

> ON THE EXAM
>
> Perimeter policies prevent. External access findings prove the prevention is working.

Reaching private apps: VPN or Verified Access?

CLIENT VPN

Join the network

- User lands inside the VPC
- Reach governed by routes and groups
- Checked once, at connection
- Broad access once connected

AWS VERIFIED ACCESS

Reach one application

- No network access granted
- Policy per application, in Cedar
- Identity and device posture
- Evaluated on every request

THE TIEBREAKER

Per-application access with device posture and no VPN means Verified Access.

Verified Access building blocks

PIECE	WHAT IT DOES
Trust providers	Identity: IAM Identity Center or OIDC. Device: e.g. CrowdStrike, Jamf
Groups and policies	Cedar rules on identity and device claims
HTTP endpoints	Web apps behind a load balancer or network interface
TCP endpoints	RDS, NLB, network interface or CIDR, for SSH, RDP, databases
Connectivity Client	Required on the device for TCP endpoints

ON THE EXAM

Since February 2025 Verified Access covers TCP as well as web, so SSH and database access are in scope.

A server outside AWS should prove who it is with **something it already has**, not an access key someone pasted in.

IAM Roles Anywhere

- **Trust anchor:** your certificate authority, AWS Private CA or your own.
- **Profile:** which roles may be assumed, with optional session policies.
- **Credential helper** signs with the private key and returns temporary credentials.
- **Role trust** can match certificate attributes, such as subject or issuer.
- **Revocation** by imported certificate revocation lists.

> ON THE EXAM
>
> The workload already has an X.509 certificate from your PKI: Roles Anywhere.

Certificate or token?

IAM ROLES ANYWHERE

Workload holds a certificate

- On-premises servers with corporate PKI
- Devices with X.509 certificates
- Trust anchor is your CA
- Credential helper on the host

OIDC WEB IDENTITY FEDERATION

Workload holds a token

- Jobs in another cloud with OIDC tokens
- CI systems such as GitHub Actions
- IAM OIDC identity provider
- AssumeRoleWithWebIdentity

THE TIEBREAKER

Match the mechanism to what the workload already has: a certificate, or an OIDC token.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Credentials used from outside our network	SCP with SourceIp or SourceVpc, service exemptions
No outsider may reach any of our buckets	RCP with aws:PrincipalOrgID
Traffic through the endpoint, our things only	VPC endpoint policy
Contractors, one app, device posture, no VPN	Verified Access
On-premises servers with certificates	IAM Roles Anywhere
Workload in another cloud with OIDC tokens	Web identity federation

ON THE EXAM

Name the perimeter first: identity, resource or network. The control follows.

> A Meridian Freight developer's access keys leaked and were used from the internet. Meridian's workloads only call AWS from its own VPCs and its corporate IP range.
>
> The security team wants such credentials to be useless outside those networks, across all accounts, without breaking AWS services that call other services for Meridian.

What should the solutions architect implement?

A. Amazon GuardDuty with automated revocation of affected keys

B. An RCP denying access when aws:PrincipalOrgID is not Meridian's organisation

C. A bucket policy on each bucket allowing only Meridian's IP range

D. An SCP denying requests not from Meridian's VPCs or IP range, exempting aws:PrincipalIsAWSService and aws:ViaAWSService

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A GuardDuty revocation

Reacts after misuse is detected; credentials still work until then.

B RCP on organisation

The leaked keys belong to Meridian's own principal, so they pass this test.

C Bucket policies

Covers S3 only, one bucket at a time, and breaks service calls.

D SCP network perimeter

Every API, every account, with exemptions for service-to-service calls.

THE SIGNAL

Your own credentials, used from the wrong place: the identity perimeter's network condition, in an SCP.

> Meridian Freight has 900 S3 buckets across 60 accounts, and teams create new ones every week. A review found two bucket policies that granted read access to an unknown external account.
>
> Security wants a guarantee that no identity outside the organisation can access any bucket, whatever future bucket policies say.

What should the solutions architect implement?

A. An SCP denying s3:PutBucketPolicy for all principals

B. An RCP for S3 that denies access unless aws:PrincipalOrgID matches Meridian's organisation, with an exemption for AWS service principals

C. An external access analyser with alerts on new findings

D. An AWS Config rule that removes non-compliant bucket policies

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **Deny PutBucketPolicy**

Stops all bucket policies, including legitimate ones, and does not fix existing ones.

B **RCP on S3**

Overrides any bucket policy, existing or future, for outside identities.

C **External access analyser**

Detects, but does not guarantee anything.

D **Config remediation**

Leaves a window between the change and the fix.

THE SIGNAL

Outsiders, every resource, whatever the resource policy says. That is a resource perimeter, and an RCP.

> Meridian Freight's on-premises billing servers call Amazon S3 and Amazon SQS using IAM user access keys stored in configuration files. Each server already has an X.509 certificate issued by Meridian's corporate certificate authority.
>
> The company wants to remove long-lived keys without changing application code.

What should the solutions architect recommend?

A. IAM Roles Anywhere, with the corporate CA as a trust anchor and the credential helper on each server

B. Rotate the access keys every 30 days with Secrets Manager

C. A Cognito identity pool that issues credentials to the servers

D. AWS Verified Access in front of S3 and SQS

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A IAM Roles Anywhere

Certificates already exist; the helper supplies temporary credentials to the SDK.

B Rotated keys

Still long-lived keys, and reading the secret needs credentials too.

C Cognito identity pool

Designed for application users, not servers.

D Verified Access

For people reaching private applications, not workloads calling AWS APIs.

THE SIGNAL

Servers outside AWS with certificates from your own CA. That sentence describes Roles Anywhere.

> External auditors need access to Meridian Freight's internal compliance web app and to a reporting database on Amazon RDS, both in private subnets.
>
> Access must be per application, require a healthy managed laptop, and avoid giving the auditors any network access to the VPC.

What should the solutions architect implement?

A. AWS Client VPN with authorisation rules for the two subnets

B. A public Application Load Balancer with Cognito authentication

C. AWS Verified Access with an identity trust provider and a device trust provider, an HTTP endpoint for the app and an RDS endpoint for the database

D. A bastion host in a public subnet with SSH tunnelling

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **Client VPN**

Gives network access to whole subnets, which the scenario rules out.

B **Public ALB with Cognito**

Web only, publicly exposed, and no device posture check.

C **Verified Access**

Per-app policies with device posture, covering web and RDS endpoints.

D **Bastion host**

Network access through a hardened host, and no device checks.

THE SIGNAL

No network access, per application, device posture, and a database. Verified Access with a TCP endpoint.

> A Meridian Freight analytics job runs in another cloud provider and must write results to an S3 bucket in AWS. The job's platform issues it an OIDC identity token automatically.
>
> The company runs no certificate authority and wants no long-lived AWS keys.

What should the solutions architect recommend?

A IAM Roles Anywhere with a new AWS Private CA

B An IAM user with keys stored in the other cloud's secret store

C AWS Verified Access in front of the bucket

D An IAM OIDC identity provider for that platform's issuer, and a role assumed with AssumeRoleWithWebIdentity

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A **Roles Anywhere with Private CA**

Works, but adds a CA and certificate handling the job does not need.

B **IAM user keys**

Long-lived keys, which the scenario rules out.

C **Verified Access**

For people reaching applications, not jobs calling S3.

D **OIDC web identity federation**

Uses the token the job already has; no CA, no keys.

THE SIGNAL

The workload already holds an OIDC token. Federate it; do not build a PKI to issue certificates.

Meridian Freight's data processing VPC reaches Amazon S3 through a gateway endpoint and has no internet access.

Security wants traffic through the endpoint to reach only buckets owned by the organisation, and only by identities from the organisation, so that stolen external credentials cannot be used to copy data out.

What should the solutions architect configure?

A. A VPC endpoint policy allowing S3 actions only when aws:PrincipalOrgID and aws:ResourceOrgID match the organisation

B. A network ACL allowing only the S3 prefix list

C. S3 Block Public Access on every account

D. A security group allowing outbound HTTPS only

◆ PAUSE AND DECIDE

What should the solutions architect configure?

A VPC endpoint policy

Filters every request on the path by both identity and resource.

B Network ACL

IP ranges cover all of S3, so any bucket is still reachable.

C Block Public Access

Protects Meridian's buckets, not traffic to an attacker's bucket.

D Security group

Port-level, with no view of buckets or identities.

THE SIGNAL

Only network-layer control that understands identities and buckets: the endpoint policy.

What to carry out of this module

- **Trusted identities, trusted resources, expected networks**, all three.
- **SCP** for your principals, **RCP** for your resources, **endpoint policy** for the path.
- **Exempt service calls** in network conditions, or the perimeter breaks things.
- **Verified Access** for per-app access with device posture, web or TCP.
- **Certificate means Roles Anywhere; OIDC token means web identity.**

> ON THE EXAM
>
> Name the perimeter that failed, then pick the policy type attached to that side.